ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Cisco Catalyst 9300 Series Switch (IOS-XE) · Component type: **Network Device (NDR)** · Target SL = SL 3

Where to work	**IOS-XE CLI** via console and **SSHv2**; **HTTPS Device Manager / WebUI**; RADIUS/TACACS+ (ISE). Review with **show** commands (read-only). Config archive for change tracking.
Interfaces / ports	**SSH 22**; **HTTPS 443** (WebUI/RESTCONF); **Telnet 23** (must be disabled); **SNMPv3 161**; RADIUS 1812/1813; TACACS+ 49; NTP 123; Syslog 514; NetFlow.
Firmware note	IOS-XE **17.x**. MACsec / advanced features require the **Network Advantage** license. Confirm model (C9300-xx) and IOS-XE version with `show version`.
CLI syntax (IOS-XE — differs from classic IOS)	This is **IOS-XE**: syntax differs from classic-IOS switches (IE4010 / Stratix 5400 / 5700). MACsec verify = `show macsec interface <if>` / `show macsec summary` + `show mka sessions`. 802.1X sessions = `show access-session` (current) **or** `show authentication sessions` (legacy alias — both accepted on IOS-XE). Stack/redundancy = `show switch` / `show redundancy` (**not** `show standby`, which is HSRP-only). Boot/image trust = `show software authenticity running` **plus** Trust-Anchor `show platform hardware authentication status` / `show platform software integrity`. Change audit = `show archive log config all`. Local users = `show running-config | include username` + `show users` (there is no `show local user accounts`, `show file integrity`, or `show crypto policy`).
How to read	Default read-only (show commands). Each row = native CLI/WebUI how-to + external-tool validation + pass. Write/exploit tools = **isolated/representative env + written authorization**.

Session setup & evidence handling

Do this BEFORE running any command so the evidence is complete, attributable, and protected:
1. Start a full session log first. PuTTY: Session › Logging → select **All session output** → set **Log file name** (browse to the encrypted evidence folder) → under "if the log file already exists" pick **Always append** → tick **Include header** and (Logging › Options) **Flush log frequently**; put `&Y&M&D_&T` in the name for an auto timestamp. (SecureCRT: File › Log Session; Tera Term: File › Log; macOS/Linux: `script -a <file>.log` or `ssh user@host | tee <file>.log`.)
2. Name the file to the evidence convention (one file per device): `<site>_<zone>_<assetTag>_<vendor>_<model>_<mgmtIP>_<YYYYMMDD-HHMM>_<testerInitials>.log`.
3. Disable paging so full output is captured (it resets each login): disable paging: `terminal length 0` (also `terminal exec prompt timestamp` to stamp each command); restore with `terminal length 24` when done.
4. Self-document the log - capture identity/time first: `show clock` then `show version`, so the file proves what/when/who.
5. Close out: restore paging, stop the log (PuTTY closes it when the session ends), and verify the file opened/saved.
6. Protect the evidence file. It contains running-config and may hold hashes, SNMP community strings, or keys: store **only** on the encrypted assessment share, follow the project data-classification/retention policy, redact secrets before sharing, and **never** email it in cleartext. **Do not save the device password in the PuTTY/SecureCRT saved session** - authenticate interactively or via the approved password manager.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / license
SR/CR 1.1	Human user I&A	Confirm AAA is on: `show run | sec aaa` shows `aaa new-model` + `aaa authentication login default group tacacs+ local`. SSH only: `show ip ssh` (v2), lines use `transport input ssh`, **no** `transport input telnet`; `no ip http server` + `ip http secure-server`. **Test:** console/SSH/HTTPS without creds -> denied; Telnet refused. **Ext. tools:** SSH client; RADIUS/TACACS+ test client (ISE); Nmap (confirm only 22/443 auth services); ReadOnlyEnum.	All mgmt interfaces authenticate; invalid creds rejected; no Telnet/anonymous/default path.	Telnet + HTTP must be off on SL-3.
SR/CR 1.2	Device & software-process I&A	Port authentication: `show authentication sessions` / `show dot1x all` for **802.1X / MAB**; switch-to-switch **MACsec**: `show mka sessions` + `show macsec interface <if>`. SNMP requires v3 user auth. **Test:** a rogue endpoint on an 802.1X port lands in the restricted/guest VLAN or is denied. **Ext. tools:** 802.1X test supplicant; rogue-endpoint device; Wireshark (EAPOL / MKA); RADIUS/ISE logs.	Only authenticated devices/peers connect; unknown endpoints quarantined; MACsec links up on trunks.	MACsec needs Network Advantage.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / license
SR/CR 1.3	Account management	Named accounts + privilege: `show run | sec username|aaa`; confirm AAA-managed identities, distinct privilege levels, and **no shared/default** accounts (no bare `username cisco`). **Ext. tools:** TACACS+/ISE account review; config review.	Individually attributable, least-privilege, lifecycle-managed accounts; no shared logins.	
SR/CR 1.4	Identifier Management	Confirm identifiers (user and device IDs) are unique, not reused, and managed over their lifecycle.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 1.5	Authenticator management	`service password-encryption` on; secrets use type 8/9 (scrypt/PBKDF2): `enable secret` and `username x secret` — **no** type-0/7 passwords (`show run | incl secret|password`). SSH keys/certs managed. **Ext. tools:** Config review (grep for weak types); ssh-audit.	Strong password hashes; no cleartext/type-7; keys/certs rotate.	
SR/NDR 1.6	Wireless Access Management	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 1.7	Strength of password auth	Verify with `show running-config | include security passwords` (shows the configured `security passwords min-length`) and `show running-config | section aaa` (any `aaa common-criteria policy`). Enforce a strong policy locally (`security passwords min-length 14` + `aaa common-criteria policy`) or via ISE/AAA password policy. **Ext. tools:** `show running-config | include security passwords`; `show running-config | section aaa`; ISE/AAA policy review.	Configurable strong password policy enforced (local or AAA).	
SR/CR 1.8	Public key infrastructure (PKI) certificates	`show crypto pki certificates` for CA-signed device certs (WebUI/RESTCONF/802.1X); `show ip ssh` for KEX/host-key/cipher strength; strong RSA(>=2048)/ECC. **Ext. tools:** sslscan / testssl.sh on :443; ssh-audit on :22.	CA-signed certs, strong keys/ciphers; weak/expired rejected.	
SR/CR 1.9	Strength of public key-based authentication	Confirm public-key authentication uses strong, current keys/algorithms. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of public key-based authentication verified individually.	
SR/CR 1.10	Authenticator Feedback	Confirm authenticators (passwords) are obscured during entry (masked) on every interface.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 1.11	Unsuccessful login attempts	Login throttling: `login block-for 100 attempts 3 within 60` + `login on-failure log`; AAA/ISE lockout. **Verify:** `show login`. **Ext. tools:** Hydra/Medusa (ISOLATED, authorized) to confirm quiet-mode/lockout engages.	Excess failures trigger lockout/quiet-mode and are logged; brute force throttled.	
SR/CR 1.12	System use notification	Login banner on all paths: `banner login` / `banner motd` (also shown by WebUI). Confirm the approved notice appears at console/SSH/WebUI. **Ext. tools:** Console/SSH; browser (HTTPS); config review.	Approved system-use banner displayed on all mgmt interfaces.	
SR/NDR 1.13	Access via untrusted networks	Restrict mgmt: `line vty` with `access-class` ACL, management VRF / OOB port, and `control-plane` protection; SSH-only; MFA via ISE for remote. No mgmt reachable from untrusted VLANs. **Ext. tools:** Nmap from each VLAN/segment (22/443 reachability); ACL review.	Mgmt-plane unreachable from untrusted networks; MFA for remote admin.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / license
SR/CR 2.1	Authorization enforcement	Command authorization: `aaa authorization commands 15 default group tacacs+` and/or role-based CLI `parser view`; privilege levels. **Test:** a low-priv user cannot enter config or run privileged show/clear. **Ext. tools:** TACACS+ command-authorization logs; login as low-priv user.	Least privilege enforced; unauthorized commands denied and logged.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / license
SR 2.3	Use Control for Portable and Mobile Devices	**N/A.** Device does not host portable/mobile-media use; USB/portable-device use is controlled at the engineering host (EWS).	N/A - justification recorded (not assessed as a control).	N/A
SR/NDR 2.4	Mobile Code	Assess per objective: Enforce usage restrictions for mobile code technologies.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 2.5	Session lock / timeout	Idle timeout on all lines: `line con 0 / line vty 0 15` -> `exec-timeout 10 0`; `service tcp-keepalives-in`. **Ext. tools:** Manual idle test; config review.	Idle sessions time out on console and vty.	
SR/CR 2.6	Remote Session Termination	Confirm remote sessions can be terminated on demand and on inactivity timeout.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 2.7	Concurrent Session Control	Confirm concurrent-session limits or monitoring for privileged/engineering access.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 2.8	Auditable events	AAA accounting + config-change logging: `aaa accounting commands 15 default start-stop group tacacs+`; `archive` -> `log config` -> `logging enable / notify syslog`. **Test:** change config -> syslog + `show archive log config all` entry with user. **Ext. tools:** Syslog server; `show logging`	Security-relevant events (login, config change, command) logged with user + timestamp.	
SR/CR 2.9	Audit Storage Capacity	Confirm audit/log storage is sized and rotated and alerts before overflow (or offloads to syslog/SIEM).	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 2.10	Response to Audit Processing Failures	Confirm defined behavior on audit/log processing failure (alert; do not silently drop events).	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 2.11	Timestamps	`service timestamps log datetime msec localtime show-timezone`; authenticated NTP: `ntp authenticate` + `ntp authentication-key` + `ntp server ... key`. **Ext. tools:** Wireshark (NTP); `show ntp status`.	Accurate authenticated time; logs carry synced timestamps.	
SR/CR 2.12	Non-repudiation	AAA command accounting + config archive record the **username** for each change. Confirm attribution in `show archive log config all` and TACACS+ logs. **Ext. tools:** TACACS+ accounting review.	Every change attributable to a named user.	
NDR 2.13	Physical Diagnostic/Test Interfaces (Network)	Assess the NDR-specific requirement per objective: Network device shall protect against unauthorized use of physical diagnostic and test interfaces.	Met per SL-3 - verify and capture evidence.	NDR completeness

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / license
SR/CR 3.1	Communication integrity	Mgmt via SSH/HTTPS/SNMPv3 (auth+priv) only; data-plane integrity via **MACsec** on trunks; `control-plane` policing. Confirm no cleartext mgmt (no Telnet/HTTP/SNMPv1-2c). **Ext. tools:** Wireshark (confirm encrypted mgmt; MACsec on links); Nmap.	All mgmt/data integrity-protected; cleartext protocols disabled.	
SR/NDR 3.2	Protection from malicious code	Image authenticity / secure boot (Trust Anchor): `show software authenticity running` and `show platform integrity`; load only Cisco-signed IOS-XE from CCO; verify `verify /md5`. **Ext. tools:** Signature/hash cross-check vs Cisco.com.	Only signed IOS-XE runs; secure-boot/Trust-Anchor integrity intact.	
SR/CR 3.3	Security functionality verification	Compare running config to the hardened baseline; protect and hash the image; use `configure replace` from a trusted archive. Verify no unauthorized config drift. **Ext. tools:** Config diff vs baseline; RANCID/Oxidized (config integrity).	Config matches baseline; image integrity verified; drift detected.	
SR/CR 3.4	Software & information integrity	Confirm software & information (config/program) integrity; unauthorized change prevented/detected. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Software & information integrity verified individually.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / license
SR/CR 3.5	Input Validation	Assess per objective: Validate syntax and content of any process control input.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 3.6	Deterministic Output	**N/A.** Device does not drive process outputs; deterministic/fail-safe output is not applicable.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 3.7	Error Handling	Confirm errors are handled gracefully without leaking sensitive information or losing control.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 3.8	Session integrity	SSH/TLS sessions protect against hijack/replay; disable weak SSH algos: `ip ssh server algorithm mac/encryption/kex ...` (strong only). **Ext. tools:** ssh-audit; sslscan.	Strong session crypto; weak algorithms disabled.	
SR/CR 3.9	Protection of Audit Information	Confirm audit records are protected from unauthorized read/modify/delete (permissions + offload).	Met per SL-3 - verify on the product and capture evidence.	completeness
NDR 3.10	Support for updates	Signed IOS-XE upgrade + rollback via `install add/activate/commit` (and ISSU on stacks); verify rollback path. **Ext. tools:** Lab upgrade/rollback test.	Signed updates with tested rollback; authenticity enforced.	NDR-specific.
NDR 3.11	Physical tamper resistance & detection	Locked rack; control console/AUX; disable USB `platform usb disable`; verify boot integrity `show platform integrity` (Trust Anchor / secure boot). **Ext. tools:** Physical inspection; `show platform integrity`	Physical access controlled; USB disabled; verified secure boot.	NDR-specific.
NDR 3.12	Provisioning Supplier Roots of Trust (Network)	Assess the NDR-specific requirement per objective: Network device shall provision and protect product-supplier roots of trust used to validate firmware/identity.	Met per SL-3 - verify and capture evidence.	NDR completeness
NDR 3.13	Provisioning Asset Owner Roots of Trust (Network)	Assess the NDR-specific requirement per objective: Network device shall support provisioning and protection of asset-owner roots of trust.	Met per SL-3 - verify and capture evidence.	NDR completeness
NDR 3.14	Integrity of the boot process	Confirm integrity of the boot process — only signed/verified firmware boots (device requirement). **Steps:** for this product this is assessed with the same evidence as **NDR 3.11** above (shared steps); confirm this requirement individually and adjudicate it separately.	Integrity of the boot process verified individually.	NDR-specific.

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / license
SR/CR 4.1	Information confidentiality	SNMPv3 priv (AES), SSH/HTTPS/MACsec; disable SSHv1 and weak ciphers/KEX (`ip ssh server algorithm encryption aes256-gcm ...`); TLS 1.2/1.3 on WebUI/RESTCONF. **Ext. tools:** sslscan/testssl.sh (:443); ssh-audit (:22); Wireshark.	Modern TLS/SSH ciphers; SNMPv3 priv; weak protocols disabled.	
SR/CR 4.2	Information Persistence	Confirm sensitive data can be purged/sanitized on decommission or re-use.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 4.3	Use of cryptography	Confirm use of modern cryptography (strong suites, managed keys; weak/legacy disabled). **Steps:** for this product this is assessed with the same evidence as **SR/CR 4.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Use of cryptography verified individually.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / license
SR/CR 5.1	Network segmentation	VLAN/PVLAN + ACL segmentation and VRFs isolate zones; verify `show vlan brief`, `show access-lists`, private-VLAN config; unused ports in a black-hole VLAN and `shutdown`. **Ext. tools:** Nmap across VLANs; ACL review.	Effective segmentation; inter-zone flows restricted to policy.	
SR/NDR 5.2	Zone boundary protection	ACLs / CoPP at boundaries; VTY `access-class`; `show policy-map control-plane`. Only required flows cross the boundary. **Ext. tools:** Nmap at boundary; ACL/CoPP review.	Boundary enforces least-flow; control-plane protected.	
SR/NDR 5.3	General Purpose Person-to-Person Communication Restrictions	Assess per objective: Prevent general purpose messages from external users/systems.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR 5.4	Application Partitioning	**N/A.** Single-purpose device; no separable applications to partition (handled at the host/SCADA layer).	N/A - justification recorded (not assessed as a control).	N/A

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / license
SR/CR 6.1	Audit log accessibility	Central syslog: `logging host <server>` + `logging trap informational`; `show logging` readable/exportable by authorized staff. **Ext. tools:** Syslog server; log export.	Logs centralized and accessible/exportable to authorized users.	
SR/CR 6.2	Continuous monitoring	Ship syslog + SNMPv3 traps to the SIEM; enable **Flexible NetFlow** (`flow monitor`) to a collector; monitor CoPP/security counters. **Ext. tools:** Syslog listener (`nc -lu 514`); NetFlow collector; SIEM.	Logs/flows/traps monitored; alerting on security events.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / license
SR/CR 7.1	Denial-of-service protection	Control-plane policing (CoPP), `storm-control`, `ip dhcp snooping`, dynamic ARP inspection, `spanning-tree bpduguard`, `switchport port-security`. Verify `show policy-map control-plane`. **Ext. tools:** Traffic generator / flood test (ISOLATED); counters review.	Switch remains manageable/forwarding under storm; protections active.	
SR/CR 7.2	Resource management	Monitor `show processes cpu sorted` + `show processes memory sorted`; hardware/TCAM limits; enforce connection/rate limits at boundary. **Ext. tools:** SNMP/telemetry monitoring.	CPU/memory/TCAM within bounds under peak; no exhaustion.	
SR/CR 7.3	Control system backup	Config archive: `archive` + `path` + scheduled `write memory`; back up via SCP; recover with `configure replace` or reload from archive; test on a spare/stack member. **Ext. tools:** SCP backup; `sha256sum` of config; lab restore.	Recent verified config backup; restore/rollback tested.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / license
SR/CR 7.6	Network & security config settings	Document + baseline all security settings; capture in the archive; changes via change control (`show archive`). **Ext. tools:** RANCID/Oxidized baseline compare.	Settings documented, baselined, change-controlled.	
SR/CR 7.7	Least functionality	Disable unused services: `no ip http server`, Telnet, `no cdp run` where not needed, `no service pad`, `no ip source-route`, `no ip bootp server`; `shutdown` unused ports; SNMPv3-only. **Ext. tools:** Nmap (open services); config review.	Only required services/ports enabled; insecure services disabled.	
SR/CR 7.8	Component inventory	`show version`, `show inventory`, `show module` capture model, IOS-XE version, license, and stack members. **Ext. tools:** ReadOnlyEnum; passive OT monitor.	Complete model/version/license inventory captured.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
Console / SSH (IOS-XE CLI)	Native config review (all)	Authenticated CLI via console or SSHv2; run `show` commands read-only. Use an authorized least-privilege account.	Read-only review; no changes on production.
WebUI (HTTPS Device Manager)	Config review via browser (1.1, 4.x)	Browse the WebUI over HTTPS; review users, banners, certificate.	HTTPS only; authorized account.
RADIUS / TACACS+ client (ISE)	AAA authn/authz/accounting (1.1, 2.1, 2.8)	Use test identities; verify authentication, command authorization, and accounting in the server logs.	Test identities; review server logs.
Nmap	Port/service exposure & segmentation (1.1, 1.13, 5.x, 7.7)	`nmap -sT -p 22,23,80,443,161 -T2 <sw>`; scan from each VLAN/segment to prove segmentation; confirm 23/80 closed.	Tune timing (-T2) on production.
sslscan / testssl.sh	WebUI TLS strength (1.8, 3.8, 4.3)	`sslscan <sw>:443` / `testssl.sh https://<sw>`; confirm TLS 1.2/1.3 only, strong ciphers, valid cert.	Read-only/safe.
ssh-audit	SSH algorithm strength (1.8, 3.8, 4.3)	`ssh-audit <sw>`; confirm strong KEX/cipher/MAC; SSHv1 and weak algos disabled.	Read-only.
Wireshark / tcpdump	Comm integrity, MACsec, monitoring (1.2, 3.1, 6.2)	SPAN/tap capture; confirm mgmt is encrypted, MACsec on trunks, EAPOL/MKA on 802.1X ports; inspect NTP.	Passive; SPAN/tap only.
802.1X test supplicant / rogue device	Port authentication (1.2)	Present authorized then unauthorized endpoints on an 802.1X/MAB port; confirm auth grants and rogue is denied/quarantined.	Coordinate with NAC team.
Syslog server / SIEM + NetFlow collector	Audit & monitoring (2.8, 6.1, 6.2)	Confirm logs, command accounting, and flows arrive; trigger an event and verify receipt.	Coordinate with SIEM team.
RANCID / Oxidized	Config integrity & drift (3.3, 3.4, 7.6)	Automated config capture; diff running config vs the hardened baseline to detect drift.	Read-only.
Hydra / Medusa	Login lockout behavior (1.11)	Authorized repeated SSH/WebUI logins to confirm login-block/quiet-mode engages.	ISOLATED/authorized only.
Traffic generator / packet flooder	DoS resilience (7.1)	Storm/flood test to confirm CoPP/storm-control keep the switch manageable and forwarding.	ISOLATED/non-production; authorization.
Nessus / OpenVAS	Known-CVE scan (3.2, general)	Authenticated scan for known IOS-XE CVEs; cross-check Cisco PSIRT advisories.	ISOLATED/representative; authorization.
ReadOnlyEnum	Host/network enumeration (7.8)	Enumerate exposed services/ports read-only.	Read-only.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.